

```
[.venv] (base) mariamrukhaisa@Mariams-MBP python-rekor-monitor-template % python3 main.py --consistency --tree-id 1193080599916656586 --tree-size 5114308 --root-hash aaf728964a0128557a6a89c5cb66622212442b97b15d8093f5d8cbbd747676d7
Consistency verification successful
[.venv] (base) mariamrukhaisa@Mariams-MBP python-rekor-monitor-template %
```

A threat analysis of the in-toto layout

1. Two scenarios:

- a. **The script is modified after the checkout** - The create-artifact step expects the original material. The MATCH WITH PRODUCTS FROM checkout rule will not accept the modified script since the hashed version will no longer match the version recorded by the checkout step, so the DISALLOW * rule after it causes verification to fail.
 - b. **The script is modified on the upstream repository** - If the malicious script is available on GitHub, then during the checkout step, the creation of create_artifact.py will be valid since the layout doesn't specify what the correct content of the file should be. Therefore, the checkout step will succeed, and then create-artifact will receive the same malicious file, so its MATCH rule will also succeed. To prevent this, there could be a check that validates the content of the file and makes sure it contains the expected content. There could also be verification against a trusted hash or trusted version of the file to make sure the correct script was downloaded.
2. **The developer's signing key is stolen** - Verification would succeed since the create-artifact step needs only one valid developer to sign the link metadata, and if one key is stolen, the attacker can sign the malicious build's link metadata. To prevent this from happening, the layout can require more authorized developers to sign it, meaning the threshold could be increased from one. The likelihood of all of those developers' keys being stolen would decrease dramatically, and stealing just one key would no longer be enough.
 3. **The release manager creates the artifact.md themselves without the create-artifact step** - Verification would fail because the layout expects artifact.md from the sign step to MATCH the product from the create-artifact step. If create-artifact never runs, there would be no product or link metadata for the release manager's artifact.md to match and the step's threshold of 1 link signed by the developer key would not be met. So, even if the file is signed, not all the steps were followed, and the verification would fail.
 4. **An attacker reuses valid link metadata from last week's run alongside this week's artifact.md** - If this week's artifact.md has different content, verification would fail because its hash would not MATCH the hash recorded in last week's link metadata, so the MATCH artifact.md WITH PRODUCTS FROM sign rule in the verify-delivered-artifact inspection would not accept it. However, if this week's artifact.md has the same content, verification would succeed because the hashes would still match and the layout does not check which specific run the link metadata belongs to. To prevent this from happening, a unique build ID or timestamp could be added to make sure the link metadata corresponds to a specific run.
 5. **The release manager edits the artifact.md they received from the create-artifact step** - Verification would fail because the sign step expects artifact.md to MATCH the product from the create-artifact step. If the release manager edits the file before signing

it, its hash will no longer match the version produced by the create-artifact step. Therefore, the MATCH rule would fail, and the modification would be detected.

6. **The layout signing key is compromised** - Verification would succeed since the attacker could use the stolen layout signing key to modify the layout rules and sign the malicious layout with a valid key. The verifier would then consider the modified layout legitimate because the signature is valid. To prevent this from happening, the layout could require multiple authorized owners to sign it instead of relying on only one signing key. This way, stealing just one layout signing key would no longer be enough to modify and authorize the layout.